

UNIVERSIDAD MAYOR DE SAN ANDRÉS

Carrera de Informática – Seguridad de la Información



Proyecto: Evaluación de seguridad de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – Evaluación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Luis Gael Alvarez Portugal

Fecha: 18/05/26

Clasificación del documento: Académico / Confidencial

Análisis hipotético y planificación ofensiva

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis de superficie de ataque, identificación teórica de vulnerabilidades y simulación de vectores de ataque sobre el sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

Debido a limitaciones del entorno, las evaluaciones fueron realizadas mediante análisis audiovisual del sistema y revisión conceptual de seguridad ofensiva.

2. OBJETIVOS

2.1 Objetivo General

Ejemplo:

Evaluar teóricamente la seguridad del sistema Pet Spa mediante técnicas de reconocimiento, análisis de autenticación, revisión de controles RBAC (Control de Acceso Basado en Roles) y simulación de pruebas de intrusión.

2.2 Objetivos Específicos

- Analizar el sistema de autenticación.
- Evaluar posibles debilidades JWT (JSON Web Token).
- Identificar riesgos de escalación de privilegios.
- Evaluar políticas de contraseñas.
- Detectar malas prácticas visibles.
- Proponer medidas de mitigación.

3. ALCANCE

Aquí defines qué módulos se analizaron.

Ejemplo:

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Recepción
- Groomer
- Cliente
- Gestión de usuarios

- Reportes
- Reservas
- Historiales

LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica basada en material audiovisual proporcionado por terceros. No se contó con acceso directo al entorno funcional, servidor, base de datos, APIs ni tráfico real de red, por lo que no fue posible ejecutar explotación activa ni validaciones prácticas de vulnerabilidades.

4. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis visual de autenticación
- Evaluación OWASP Top 10
- Simulación de vectores de ataque
- Evaluación RBAC
- Análisis de malas prácticas

5. RECONOCIMIENTO Y SUPERFICIE DE ATAQUE

Hallazgo	Observación	Superficie de ataque	Vulnerabilidad teórica	Pruebas hipotéticas	Simulación de ataque	Riesgo	Impacto	Severidad	Mitigación	Mejora recomendada
Registro libre de cuentas sin restricciones robustas	El sistema permite crear cuentas libremente mediante activación por correo sin CAPTCHA ni límites visibles de registro.	Registro, formularios públicos, BD, API de usuarios	Registro masivo automatizado y agotamiento de recursos	Automatización de cuentas, flood de registros, uso de correos temporales	Un atacante podría crear miles de cuentas falsas saturando la BD y degradando el servicio.	Saturación de BD y degradación del sistema	Alto	Alta	CAPTCHA, rate limiting, monitoreo anti-bot	Implementar reCAPTCHA v3, límites por IP y validación anti automatización
Ausencia de CAPTCHA en login de clientes	El login de clientes no posee CAPTCHA pese al bloqueo tras 5 intentos.	Login, autenticación, sesiones	Fuerza bruta y credential stuffing	Ataques automatizados, enumeración de usuarios, rotación IP	Un atacante podría probar múltiples credenciales filtradas hasta comprometer cuentas válidas.	Acceso no autorizado y robo de información	Alto	Alta	CAPTCHA adaptativo, bloqueo progresivo, MFA	Activar CAPTCHA dinámico y detección de comportamiento sospechoso
Validación parcial de dominios de correo	Solo algunos dominios parecen validarse, mientras Gmail puede registrarse libremente.	Registro y validación de identidad	Creación de cuentas falsas y uso de correos desechables	Registro con correos temporales, dominios falsos	Un atacante podría ocultar identidad y automatizar registros maliciosos.	Suplantación y cuentas fraudulentas	Medio	Media	Bloqueo de correos temporales y validación avanzada	Implementar validadores anti desechable email
Expiración de tokens de activación	Los tokens expiran en 15 minutos y la activación se valida desde la BD.	Tokens, activación, correo	Reutilización de tokens si no se invalidan correctamente	Replay attack, reutilización de enlaces	Un atacante podría intentar reutilizar enlaces antiguos de activación.	Activación indebida de cuentas	Bajo	Baja	Invalidación inmediata y tokens seguros	Uso de tokens únicos con revocación inmediata
Uso de bcrypt en contraseñas	El sistema utiliza bcrypt para almacenar passwords.	Base de datos y autenticación	No se evidencia vulnerabilidad directa	Validación de costo bcrypt y resistencia hash	Ante filtración de BD, bcrypt dificulta cracking offline.	Bajo riesgo de exposición de passwords	Bajo	Baja	Mantener bcrypt actualizado	Migrar a Argon2id en futuras versiones
Implementación parcial de MFA/2FA	Administradores y groomers poseen 2FA; clientes pueden habilitarlo opcionalmente.	Login administrativo y sesiones	Cuentas sin MFA pueden ser comprometidas	Bypass MFA, phishing OTP, robo de sesión	Un atacante con credenciales válidas podría ingresar a cuentas sin MFA habilitado.	Compromiso de cuentas	Medio-Alto	Media-Alta	MFA obligatorio en perfiles críticos	Aplicar MFA obligatorio para roles sensibles
Panel de auditoría y logs	Se registran IPs, navegador, hora, rol y acciones administrativas.	Logs y auditoría	Manipulación o exposición indebida de logs	Alteración de registros, log injection	Un atacante con acceso privilegiado podría borrar rastros de actividad maliciosa.	Pérdida de trazabilidad	Alto	Alta	Logs inmutables y SIEM	Implementar integridad criptográfica y almacenamiento centralizado
Posible ausencia de validaciones backend	No se observan validaciones visibles posteriores dentro del dashboard.	Dashboard, formularios internos, API	Confianza excesiva en frontend	Manipulación de requests, bypass de validaciones	Un atacante podría modificar peticiones e ingresar datos inválidos.	Corrupción de datos y abuso lógico	Alto	Alta	Validaciones server-side y sanitización	Implementar validación centralizada backend/frontend
Módulo "Preferencias adicionales" ambiguo	Campos libres poco definidos permiten ingresar información arbitraria.	Formularios dinámicos y BD	XSS almacenado y abuso de almacenamiento	Insertión masiva de texto, payloads maliciosos	Un atacante podría almacenar scripts o datos basura persistentes.	XSS y crecimiento innecesario de BD	Medio-Alto	Media-Alta	Sanitización y límites de entrada	Rediseñar módulo con campos estructurados y restricciones claras

6. RECOMENDACIONES GENERALES Y CONCLUSIONES ESPECIFICADA POR CASOS

Hallazgo 1 — Registro libre de cuentas de clientes sin restricciones robustas

Observación

El sistema permite la creación libre de cuentas mediante la opción “Crear cuenta gratis”. La validación principal consiste en la activación mediante token enviado por correo electrónico con expiración de 15 minutos.

No se observa implementación de CAPTCHA, limitación de registros por IP, validación estricta de dominios corporativos ni controles anti automatización.

Superficie de ataque

- Módulo de registro
- Formularios públicos
- Base de datos de usuarios
- Sistema de activación vía correo
- Posible API de creación de cuentas

Vulnerabilidad teórica

Posible abuso del sistema mediante automatización masiva de registros (Mass Registration Attack / Resource Exhaustion).

Pruebas hipotéticas

- Automatización de creación de cuentas mediante bots
- Generación masiva de correos temporales
- Flood de registros concurrentes
- Ataques de denegación de almacenamiento en BD
- Enumeración de correos existentes

Simulación de ataque

Un atacante podría desarrollar scripts automatizados para registrar miles de cuentas falsas utilizando correos temporales, provocando crecimiento excesivo de la base de datos, consumo de recursos del servidor y degradación del servicio.

Riesgo

- Saturación de la base de datos
- Consumo excesivo de almacenamiento
- Degradación del rendimiento
- Posible caída del sistema en producción

Impacto: Alto

Severidad: Alta

Mitigación

- Implementar CAPTCHA
- Rate limiting por IP
- Validación anti-bot
- Restricción de registros masivos
- Verificación adicional de identidad
- Monitoreo de patrones anómalos

Mejora recomendada

Implementar controles de anti automatización mediante Google reCAPTCHA v3, límites de registros por IP/dispositivo y verificación progresiva basada en reputación de correo.

Hallazgo 2 — Ausencia de CAPTCHA en autenticación de clientes

Observación

El login principal de clientes no presenta mecanismos CAPTCHA visibles pese a existir bloqueo tras 5 intentos fallidos.

Superficie de ataque

- Formulario login
- Endpoint de autenticación
- Sistema de sesiones

Vulnerabilidad teórica

Posibilidad de ataques de fuerza bruta y credential stuffing.

Pruebas hipotéticas

- Ataques automatizados de contraseñas
- Reutilización de credenciales filtradas
- Enumeración de usuarios válidos
- Bypass del bloqueo mediante rotación IP

Simulación de ataque

Un atacante podría automatizar intentos de acceso usando listas filtradas de usuarios y contraseñas hasta obtener acceso a cuentas válidas.

Riesgo

- Compromiso de cuentas
- Robo de información
- Acceso no autorizado

Impacto: Alto

Severidad: Alta

Mitigación

- CAPTCHA adaptativo
- Bloqueo progresivo
- Detección de comportamiento automatizado
- MFA obligatorio tras intentos fallidos

Mejora recomendada

Implementar CAPTCHA dinámico tras múltiples intentos fallidos y detección de anomalías basada en comportamiento.

Hallazgo 3 — Dependencia parcial de validación de dominios de correo

Observación

Se observa validación limitada para correos corporativos, mientras que cuentas Gmail pueden registrarse sin restricciones claramente definidas.

Superficie de ataque

- Registro de usuarios
- Validación de identidad
- Verificación de correo

Vulnerabilidad teórica

Posible creación de cuentas falsas mediante dominios públicos.

Pruebas hipotéticas

- Registro con correos temporales
- Uso de dominios desechables
- Creación masiva de identidades falsas

Simulación de ataque

Un atacante podría utilizar proveedores temporales de correo para generar cuentas automatizadas y ocultar su trazabilidad.

Riesgo

- Suplantación
- Creación de cuentas fraudulentas
- Incremento de superficie de ataque

Impacto: Medio

Severidad: Media

Mitigación

- Restricción de dominios temporales
- Verificación avanzada de correo
- Reputación de dominios

Mejora recomendada

Integrar validadores anti desechables email y controles de reputación DNS.

Hallazgo 4 — Implementación positiva de expiración de tokens de activación

Observación

Los tokens de activación expiran en 15 minutos y el estado de activación es validado desde la base de datos.

Superficie de ataque

- Sistema de activación
- Tokens de verificación
- Base de datos

Vulnerabilidad teórica

Aunque existe buena práctica, podría existir reutilización de tokens si no se invalidan correctamente.

Pruebas hipotéticas

- Reutilización de token expirado
- Replay attack
- Enumeración de tokens

Simulación de ataque

Un atacante podría intentar reutilizar enlaces antiguos de activación para validar cuentas fuera del tiempo permitido.

Riesgo

- Activación indebida de cuentas

- Reutilización de enlaces

Impacto: Bajo

Severidad: Bajo

Mitigación

- Invalidación inmediata del token tras uso
- Tokens aleatorios criptográficamente seguros
- Asociación del token a sesión/IP

Mejora recomendada

Implementar JWT de activación firmados con nonce único y revocación inmediata post-validación.

Hallazgo 5 — Uso de bcrypt para almacenamiento de contraseñas

Observación

El sistema utiliza bcrypt para el almacenamiento de contraseñas.

Superficie de ataque

- Base de datos
- Sistema de autenticación

Vulnerabilidad teórica

No se evidencia vulnerabilidad directa; corresponde a una buena práctica de seguridad.

Pruebas hipotéticas

- Evaluación de costo bcrypt
- Validación de salt automático
- Pruebas de resistencia hash

Simulación de ataque

En caso de filtración de la base de datos, bcrypt dificulta ataques de cracking offline.

Impacto: Bajo

Severidad: Bajo

Mitigación

- Mantener actualización del costo bcrypt
- Aplicar políticas robustas de contraseña

Mejora recomendada

Migrar eventualmente hacia Argon2id para mayor resistencia moderna frente a ataques GPU.

Hallazgo 6 — Implementación parcial de MFA/2FA

Observación

El sistema implementa 2FA para administradores y groomers mediante Google Authenticator.

Los clientes pueden habilitar MFA opcionalmente.

Superficie de ataque

- Login administrativo
- Login Groomer
- Gestión de sesiones

Vulnerabilidad teórica

La MFA opcional en clientes podría dejar cuentas vulnerables.

Pruebas hipotéticas

- Bypass MFA
- Robo de sesión
- Ataques phishing OTP
- Fuerza bruta OTP

Simulación de ataque

Un atacante que comprometa credenciales de cliente sin MFA podría acceder directamente al sistema.

Riesgo

- Compromiso de cuentas
- Escalación lateral

Impacto: Medio-Alto

Severidad: Media-Alta

Mitigación

- MFA obligatorio para cuentas críticas
- Rate limiting OTP
- Alertas de inicio sospechoso

Mejora recomendada

Hacer MFA obligatorio para todos los perfiles administrativos y opcional reforzado para clientes.

Hallazgo 7 — Panel de auditoría y logs administrativos

Observación

El sistema registra IPs, navegador, fecha, hora, rol y acciones administrativas.

Superficie de ataque

- Sistema de logs
- Panel administrativo

Vulnerabilidad teórica

Posible exposición de información sensible si los logs no son protegidos adecuadamente.

Pruebas hipotéticas

- Acceso indebido a logs
- Manipulación de auditorías
- Log injection

Simulación de ataque

Un atacante con privilegios podría alterar registros de auditoría para ocultar acciones maliciosas.

Riesgo

- Pérdida de trazabilidad
- Encubrimiento de incidentes

Impacto: Alto

Severidad: Alto

Mitigación

- Logs inmutables
- Separación de privilegios
- SIEM especializado y separado en producción para auditorías
- Integridad criptográfica

Mejora recomendada

Implementar almacenamiento centralizado de logs y firmas de integridad.

Hallazgo 8 — Posible debilidad de validaciones backend en cambios internos

Observación

No se observan validaciones visibles posteriores en cambios internos dentro del dashboard.

Superficie de ataque

- Dashboard
- Formularios internos
- API backend

Vulnerabilidad teórica

Posible omisión de validaciones backend confiando únicamente en frontend.

Pruebas hipotéticas

- Manipulación de requests
- Bypass de validaciones
- Inyección de datos inválidos

Simulación de ataque

Un atacante podría interceptar peticiones y modificar datos fuera de las restricciones inicialmente establecidas.

Riesgo

- Corrupción de datos
- Inyección de contenido inválido (no se observo modulos de validación ante inyecciones SQL)
- Inconsistencia lógica

Impacto: Alto

Severidad: Alto

Mitigación

- Validación backend obligatoria
- Sanitización
- Validaciones server-side

Mejora recomendada

Aplicar validaciones completas tanto en frontend como backend con schemas centralizados.

Hallazgo 9 — Módulo “Preferencias adicionales” con campos ambiguos

Observación

Existe un módulo con campos genéricos y poco definidos que permiten ingreso libre de información arbitraria.

Superficie de ataque

- Formularios personalizados
- Base de datos
- Inputs dinámicos

Vulnerabilidad teórica

Posible almacenamiento de datos innecesarios, payloads maliciosos o abuso de almacenamiento.

Pruebas hipotéticas

- Inserción masiva de texto
- XSS almacenado
- Inyección de scripts
- Payloads excesivos

Simulación de ataque

Un atacante podría insertar datos arbitrarios o scripts persistentes si no existe sanitización adecuada.

Riesgo

- XSS almacenado
- Inflado de BD
- Corrupción de datos

Impacto: Medio-Alto

Severidad: Media-Alta

Mitigación

- Validación estricta
- Límites de longitud
- Sanitización
- Definición clara de esquema

Mejora recomendada

Rediseñar el módulo con estructura tipada y restricciones funcionales reales

